Partie 1 – Vrai ou Faux

Répondre par **V** pour Vrai ou **F** pour Faux dans la dernière colonne du tableau ci-dessous. Donner une brève explication pour justifier votre réponse.

Énoncé	**V/F**
1) Le routeur filtrant est plus adapté au filtrage en sortie, avec une capacité de bloquer les réponses aux attaques par sondage ou balayage de ports.	V
2) Pour assurer la confidentialité de l'adressage privé, il est préférable d'utiliser IPSec en mode transport plutôt qu'en mode tunnel.	F
3) L'utilisation d'un VPN pour sécuriser une connexion transitant sur un réseau sans-fil utilisant un protocole de chiffrement (comme WPA2) est un exemple de défense en profondeur.	V
4) Les clients et le serveur VPN doivent avoir des adresses physiques sur le même réseau.	F
5) Un logiciel antivirus doit être mis à jour annuellement.	F
6) L'un des objectifs d'un Adware est de déterminer les habitudes d'achat des utilisateurs.	V
7) Un exploit découvert pour un système d'exploitation donné peut également être efficace sur un autre système d'exploitation.	V
8) Les pare-feu sont installés pour protéger le réseau interne d'une entreprise contre les dangers sur Internet.	V
9) La création d'un réseau privé virtuel (VPN) peut être réalisée par la mise en œuvre d'IPSec.	V
10) L'utilisation de l'adresse IP comme méthode d'authentification permet de lutter contre l'usurpation d'adresse IP (*IP address Spoofing*).	F

Partie 2 – Questions à choix multiples

Dans chacun des cas suivants, encercler **la** ou **les** bonnes réponses. Ne donner aucune explication.

1) Quel est le but principal des logiciels malveillants (malware)?
    a. Nuire à un système informatique
    b. apprendre les mots de passe
    c. Découvrir les ports ouverts
    d. L'identification d'un système d'exploitation

    a

2) Comment est appelé un exploit qui attaque les systèmes informatiques en insérant du code exécutable dans les zones mémoires non protégées en raison de code mal écrit?
    a. Débordement du tampon (*buffer overflow*)
    b. Cheval de Troie
    c. Virus
    d. Ver
    a

3) Comment est appelé un logiciel ou un matériel qui enregistre chaque frappe saisie par l'utilisateur?
    a. Sniffer
    b. Keylogger
    c. Cheval de Troie
    d. IPS
    b
4) Que peut-on utiliser pour réduire le risque d'un cheval de Troie ou d'un rootkit envoyant des informations à partir d'un ordinateur compromis à un ordinateur distant?
    a. Décodeur base-64
    b. Keylogger
    c. Telnet
    d. Pare-feu
    d
5) Parmi les protocoles suivants, lequel est orienté connexion avec garantie livraison (fiabilité) ?
    a. UDP
    b. IP
    c. TCP
    d. TFTP

    c

6) Quelle commande peut être utilisée pour vérifier l'existence d'une machine sur le réseau?
   a. Ping
   b. Ipconfig
   c. Netstat
   d. Nbtstat

   a

7) Pour trouver des informations sur le responsable principal du domaine (site Web) de l'entreprise, quels outils peut-on utiliser? (Choisir tout ce qui s'applique)
   a. Whois
   b. Whatis
   c. SamSpade
   d. Nbtstat

   a

8) Qu'utilisent les pare-feu pour cacher la topologie interne du réseau des utilisateurs externes?
   a. Filtrage des paquets
   b. ICMP
   c. Traceroute
   d. NAT

   d

9) Un pare-feu qui empêche une session Telnet de quitter le réseau via le port TCP 443 (port HTTPS par défaut) utilise :
   a. Filtrage dynamique
   b. Filtrage statique
   c. NAT
   d. Inspection applicative (Pare-feu applicatif)

   d

10) Pour quelles raisons peut-on utiliser un pot de miel (*honeypot*)? (Choisir tout ce qui s'applique)
   a. Leurrer ou piéger les pirates pour pouvoir les poursuivre juridiquement
   b. Collecter les informations sur les nouvelles attaques et menaces
   c. Distraire les pirates de l'attaque des ressources légitimes du réseau
   d. Protéger la zone démilitarisée (DMZ) des attaques internes

   a, b, c

Partie 3 – Développement

1) À quels besoins de sécurité répondent les mécanismes AH et ESP du protocole IPSec?
   a) **AH : authentification et intégrité.**
   b) **ESP : confidentialité, authentification et intégrité.**

2) Un pare-feu est un outil de sécurité nécessaire, mais pas suffisant, pourquoi?
   a) Un pare-feu est un outil de sécurité nécessaire mais pas suffisant dans la mesure où à lui seul, il ne peut réaliser l'ensemble des mesures de sécurité identifiées dans une politique de sécurité. Il peut contribuer à effectuer un contrôle d'accès aux ressources d'un système d'information et à en limiter la visibilité mais il ne peut en aucun cas se substituer à des mesures de **chiffrement de données**, ou de **vérification d'intégrité** par exemple. Comme tout autre outil de la sécurité, il doit être utilisé de manière cohérente et complémentaire pour satisfaire des objectifs de sécurité préalablement déterminés dans une **politique de sécurité** résultant de l'analyse des risques liés au système d'information.
   b) Un pare-feu unique constitue un point de passage obligé pour toutes les communications entrantes et sortantes et, s'il n'est pas contourné, il peut dégrader considérablement les performances du réseau. Il peut également constituer un point central de vulnérabilité (***single point of failure***). Dans un réseau, le fait de disposer comme seule mesure de sécurité des pare-feu peut introduire un faux sentiment de sécurité, préjudiciable à la protection réelle des systèmes et des données.

3) Vous avez rejoint une compagnie qui se spécialise dans la conversion de scripts étrangers pour les films d'Hollywood. Votre compagnie « Happy Endings Inc. » traduit le script, remplace tous les noms de villes par New York, les noms de personnages par John ou Julia et la fin par une fin héroïque en face d'un drapeau américain flottant au vent. Les soumissions sont faites à l'aide d'une page HTTP où chaque client se connecte à l'aide d'un nom d'usager/mot de passe. Il tombe ensuite sur une page où il peut voir tous ses fichiers et il dépose ensuite son script et, une fois l'adaptation terminée, on le notifie par courriel pour venir chercher le produit fini sur la même page. Vous souhaitez améliorer le plus possible l'application afin de, comme le veut le slogan de la compagnie, garantir une fin heureuse à toutes ses transactions. Vous passez à travers une liste de recommandations pour améliorer le système que vous a soumis votre patron.

a) Puisque vous utilisez déjà une base de données pour stocker le contenu (les scripts), on suggère de l'utiliser aussi pour stocker les informations d'authentification. Il suffit alors de faire un SELECT dans la base de données avec comme condition que le nom d'usager soit égal au nom saisi et que le mot de passe soit égal au mot de passe saisi. C'est simple, n'est-ce pas? Quelle est votre opinion sur cette amélioration?

   Ce n'est pas si simple. Ce type de code serait vulnérable à l'injection SQL. Il faudrait soit filtrer les caractères spéciaux ou encore utiliser des « prepared statements » SQL par exemple. De plus, cette solution ne protège pas adéquatement les mots de passe contre quelqu'un qui pourrait avoir accès à la Base de Données.

b) Décrivez comment un attaquant pourrait hameçonner vos clients (c'est-à-dire, utiliser l'ingénierie sociale pour leurrer vos clients).

   Le pirate fait une copie de votre site Web et envoie à votre client un courriel en prétendant que le document est prêt avec un lien vers sa page d'hameçonnage. Lorsque le client clique sur le lien, on lui présente la page d'authentification et on enregistre son nom d'usager et son mot de passe.

c) Pour se protéger contre l'hameçonnage, votre compagnie prévoit investir dans un pare-feu entre votre serveur Web et Internet. Aux dires de votre patron, le pare-feu bloquera toutes les attaques, incluant l'hameçonnage. Discutez de l'apport du pare-feu pour la protection contre l'hameçonnage.

   Le pare-feu ne protège en rien contre cette attaque puisque le protocole en question est de niveau applicatif et peut paraître bien légitime pour le pare-feu. Il est donc impossible pour le pare-feu de contrer cette attaque. Lorsque le pirate utilise les informations d'authentification volée de l'utilisateur, le trafic en question sera considéré par le pare-feu comme étant un trafic légitime.